

TP 2.2 — Analyse et correction des vulnérabilités (Linux + Windows)

Objectif

- Analyser des vulnérabilités
- Appliquer des correctifs (Linux + Windows)
- Comparer les résultats avant/après scan

Partie I — Analyse des vulnérabilités critiques

Vulnérabilités Linux :

Vulnérabilité n°1 : vsftpd 2.3.4 — Backdoor

Quel est le problème : vsftpd version 2.3.4 (binaires compromis en juillet 2011) contient un backdoor.

Quel est le risque : Prise de contrôle total de la machine en root (RCE).

Comment exploitable : Metasploit : `exploit/unix/ftp/vsftpd_234_backdoor`

Vulnérabilité n°2 : Mots de passe faibles (brute force SSH)

Quel est le problème : L'utilisateur utilise un mot de passe facilement devinable (ex: `123456`).

Quel est le risque : Accès non autorisé à la machine via SSH.

Comment exploitable : Hydra : ``hydra -l aulabs -P rockyou.txt ssh://IP`` |

Vulnérabilités Windows

Vulnérabilité n°1 : SMBv1 activé (EternalBlue — MS17-010)

Quel est le problème : Protocole SMBv1 contenant une faille de corruption mémoire.

Quel est le risque : Propagation de ransomware, prise de contrôle sans authentification.

Comment exploitable : Metasploit : ``exploit/windows/smb/ms17_010_eternalblue``

Vulnérabilité n°2 : Compte administrateur sans mot de passe

Quel est le problème : L'administrateur local n'a pas de mot de passe ou utilise `admin`.

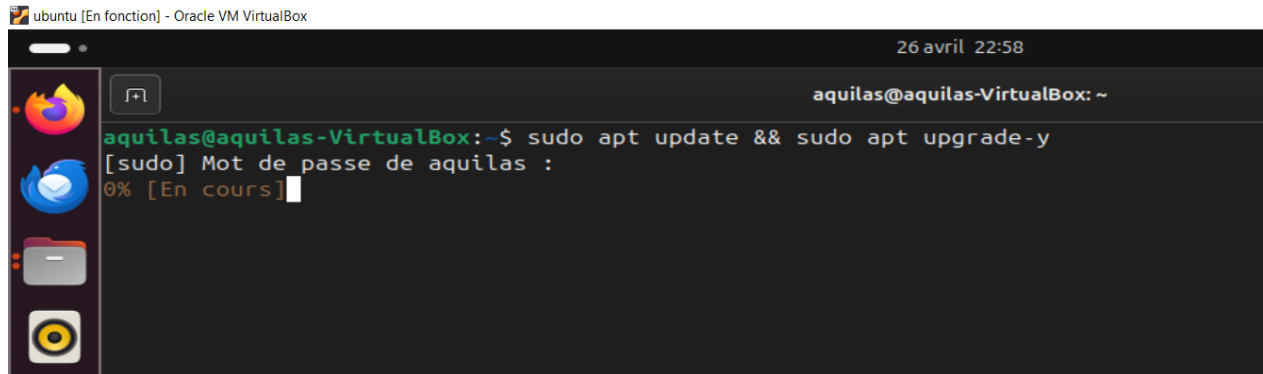
Quel est le risque : Accès privilégié direct via RDP ou connexion locale.

Comment exploitable : Hydra sur RDP (port 3389) ou connexion directe.

Partie II — Correction Linux

🔧 Correction n°1 : Mise à jour du système

`sudo apt update && sudo apt upgrade -y`



The screenshot shows a terminal window titled 'ubuntu [En fonction] - Oracle VM VirtualBox' with a timestamp of '26 avril 22:58'. The prompt is 'aquilas@aquilas-VirtualBox: ~'. The user enters the command 'sudo apt update && sudo apt upgrade -y'. The terminal shows the progress of the update, with '[sudo] Mot de passe de aquilas :' and '0% [En cours]' visible.

🔧 Correction n°2 : Désactivation des services inutiles (vsftpd)

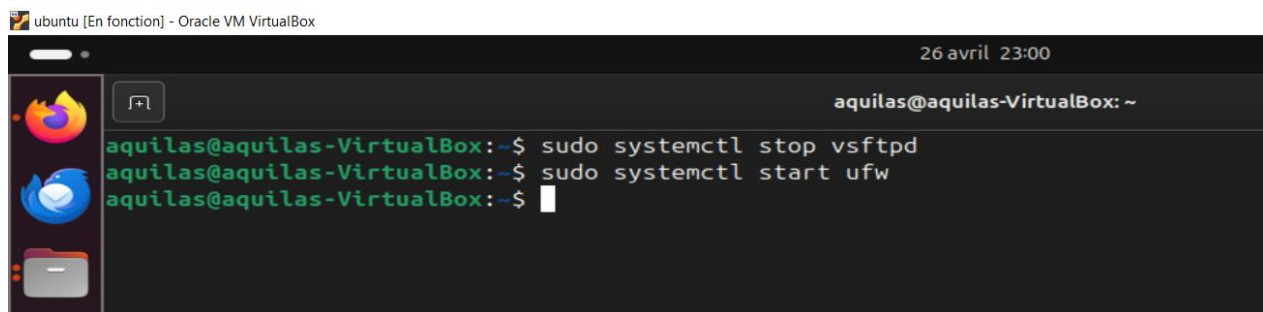
Arrêt du service vulnérable

`sudo systemctl stop vsftpd`

🔧 Correction n°3 : Configuration du pare-feu (UFW)

Activation du pare-feu

`sudo systemctl start ufw`

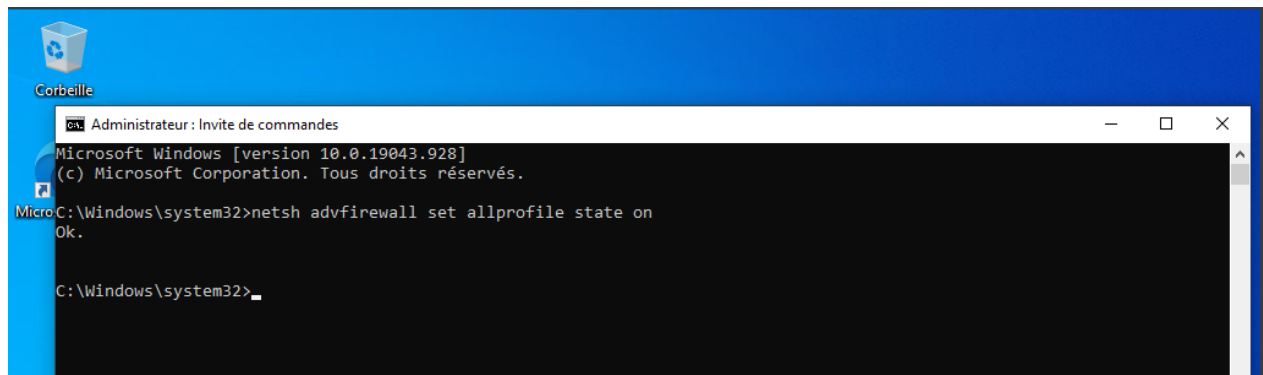


The screenshot shows a terminal window titled 'ubuntu [En fonction] - Oracle VM VirtualBox' with a timestamp of '26 avril 23:00'. The prompt is 'aquilas@aquilas-VirtualBox: ~'. The user enters the command 'sudo systemctl stop vsftpd'. The terminal shows the output 'aquilas@aquilas-VirtualBox:~\$ sudo systemctl stop vsftpd'. The user then enters the command 'sudo systemctl start ufw'. The terminal shows the output 'aquilas@aquilas-VirtualBox:~\$ sudo systemctl start ufw'.

Partie III — Correction Windows

🔧 Correction n°1 : Activation du pare-feu

`netsh advfirewall set allprofiles state on`



+ Correction n°2 : Windows Update

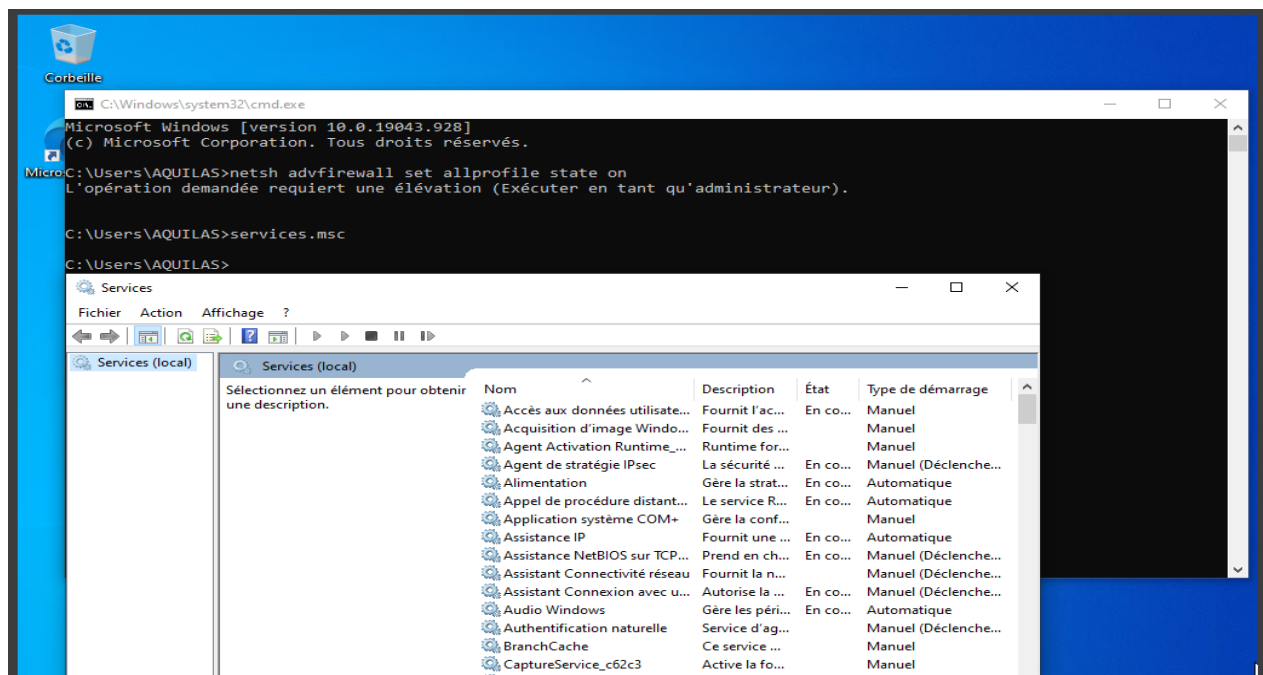
Paramètres → Windows Update → Rechercher les mises à jour → Installer

+ Correction n°3 : Désactivation des services inutiles

services.msc

Services à désactiver :

- Server (SMB si non utilisé)
- Print Spooler (si non nécessaire)
- Remote Registry



Conclusion

Ce travail pratique m'a permis de comprendre une étape essentielle en cybersécurité : **la détection ne suffit pas, il faut savoir corriger.**